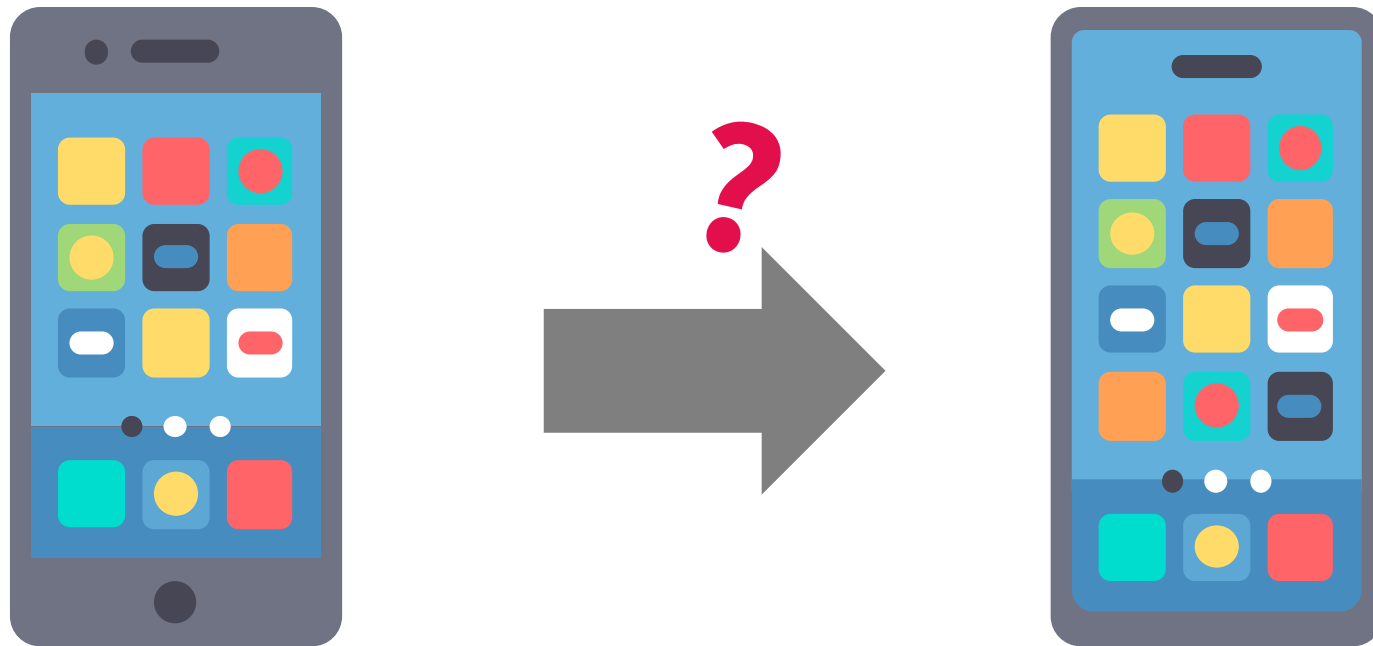


Clone2Pwn: A Systematic Security Analysis of Data Migration Tools in the Android Ecosystem

Florian Draschbacher, Lukas Maar, Lorenz Schumm, Rene Denifl, Lukas Treffner,
Stefan Mangard

ESORICS 2026

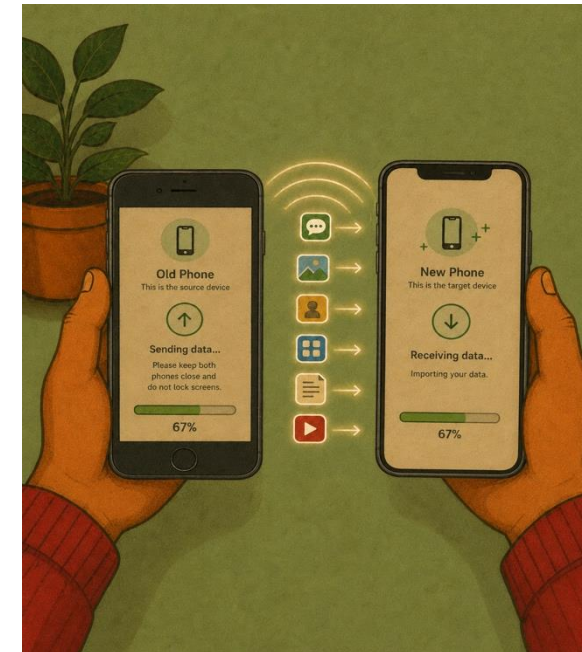
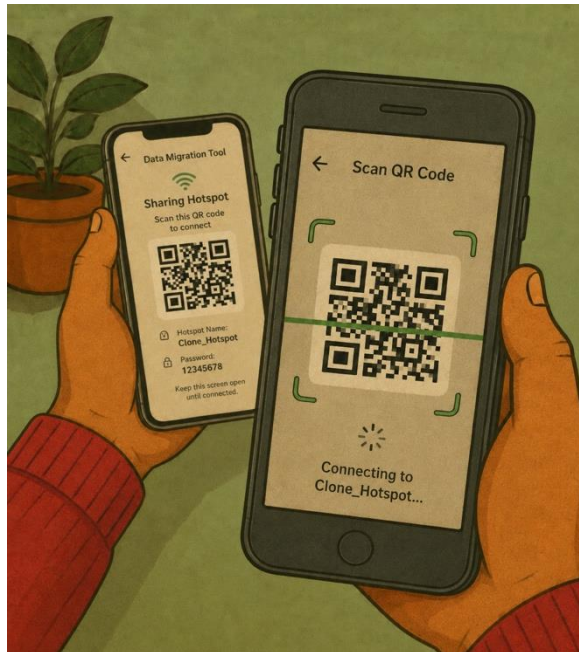
- How to migrate data and apps to a new device?

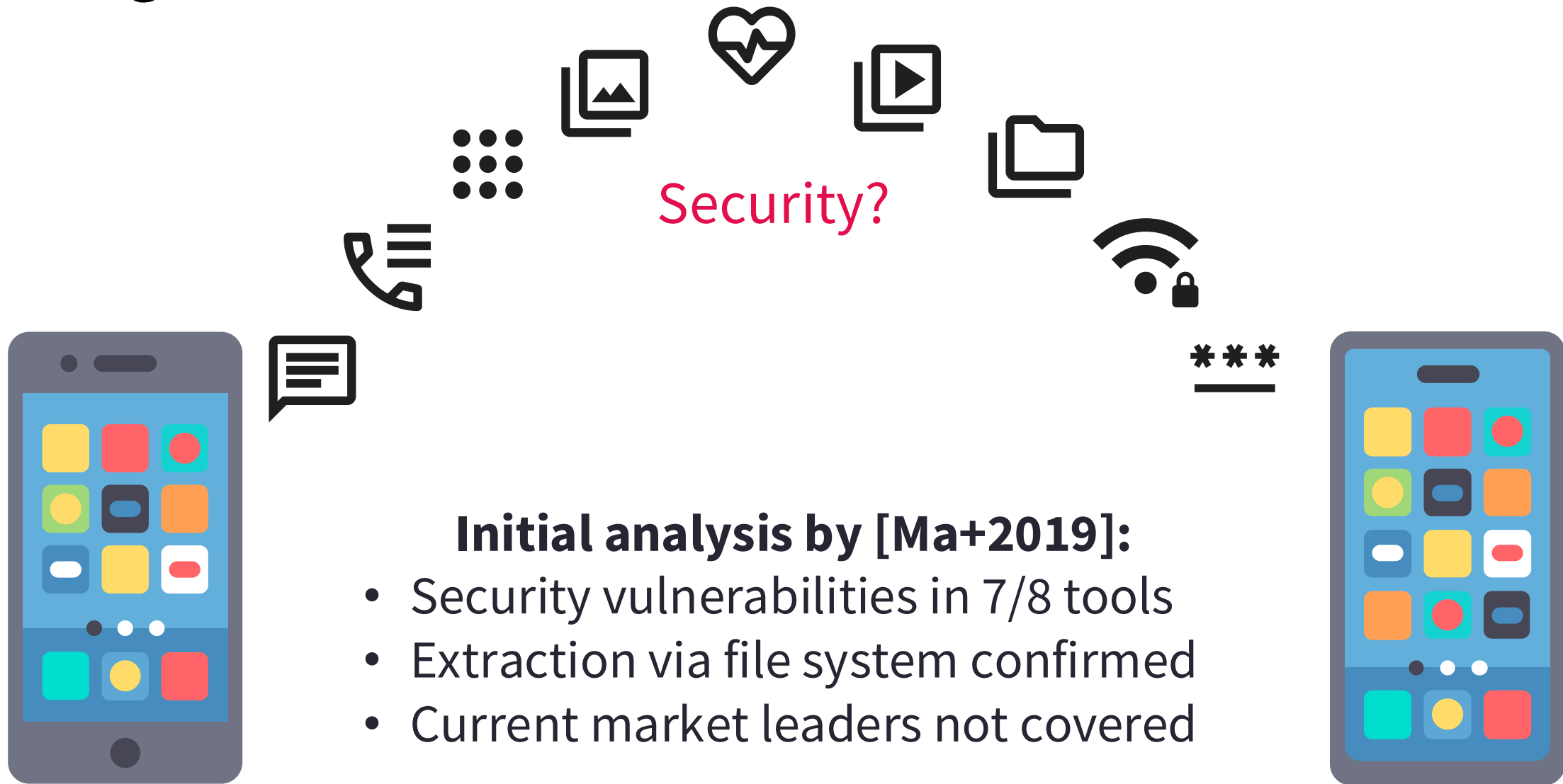


Data Migration Tools

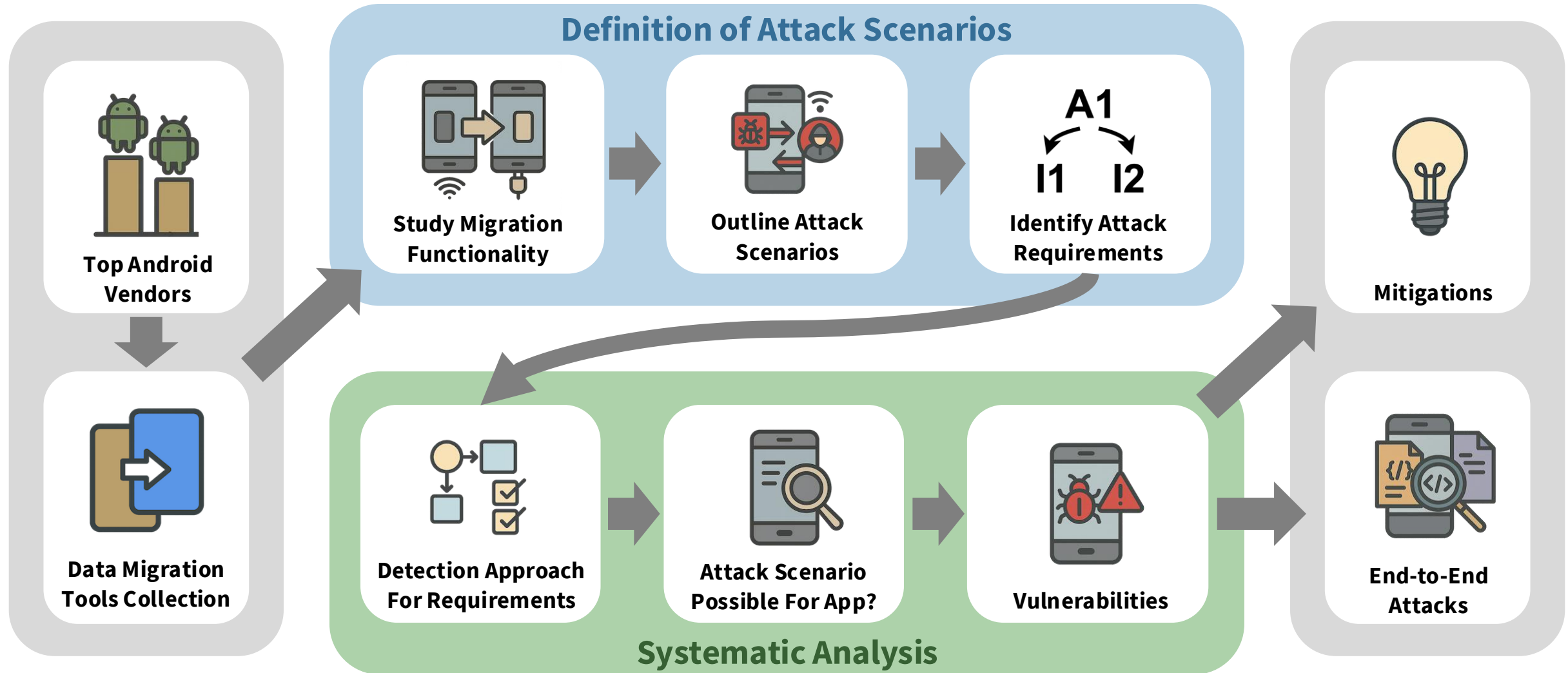
Transfer device data and apps from old phone to new one

- Offered by every major smartphone manufacturer
- Preinstalled and privileged on first-party devices
- Usually based on ad-hoc wireless connection





Clone2Pwn: Approach



Covered Migration Tools

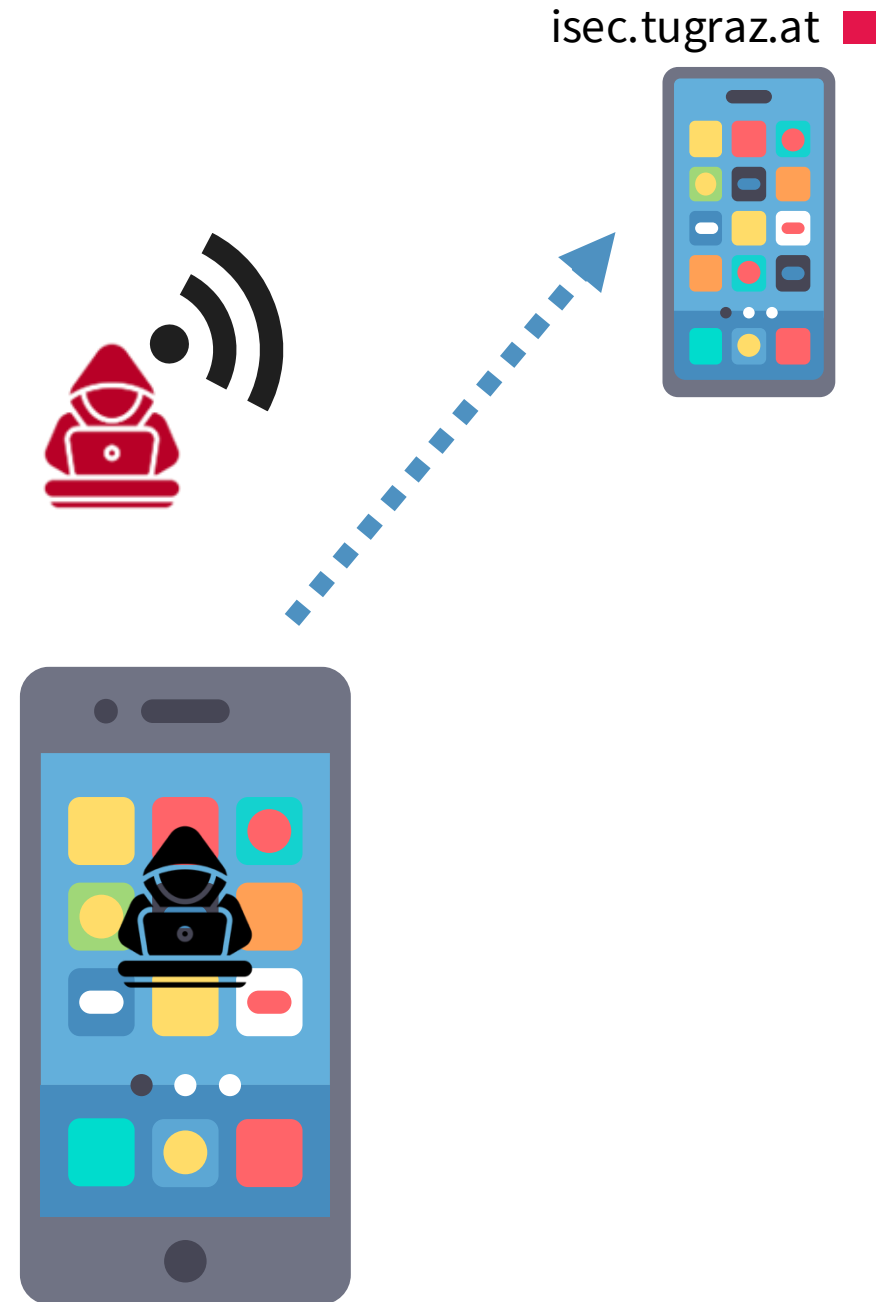
Vendor	App	Users										
			Pictures	Videos	Documents	Call Logs	Messages	Contacts	Apps	App Data	Wi-Fi Keys	Health Data
			?	?	?	?	?	?	?	?	?	?
Google	Android Switch	10B+	✓	✓	-	✓	✓	✓	-	✓	✓	✓
Samsung	Smart Switch	1B+	✓	✓	✓	✓	✓	✓	✓	✓ ¹	✓ ¹	-
Vivo	EasyShare	1B+	✓	✓	✓	✓	✓	✓	✓	-	✓ ¹	-
Xiaomi	Mi Mover	100M+	✓	✓	✓	✓	✓	✓	✓	-	✓ ¹	-
Oppo	Clone Phone	10M+	✓	✓	✓	✓	✓	✓	✓	✓ ¹	✓ ¹	-
Huawei	Phone Clone	10M+	✓	✓	✓	✓	✓	✓	✓	-	-	-
Honor	Device Clone	1M+	✓	✓	✓	✓	✓	✓	✓	-	✓ ¹	-

¹ Only first-party migrations

Attacker Models

- **M1: Proximity Attacker**
 - Within Wi-Fi range of migration
- **M2: Local Attacker**
 - Malicious app on old device

Note: No hybrid models considered



Attack Scenarios

Generic - Based on high-level operating principle of these apps

M1 Attacker

- S1 Eavesdropping on wireless communication
- S2 Manipulating wireless communication

M2 Attacker

- S3 Extracting data via local socket connection
- S4 Injecting data via local socket connection
- S5 Extracting data through file system
- S6 Injecting data through file system

Deriving Requirements

List of implementation and/or design requirements per attack scenario

Example Requirements: S2 – Manipulating wireless communication

- App is identifiable through Wi-Fi beacons
 - Wireless protection very weak (Wi-Fi AP) or pairing spoofable (Wi-Fi P2P)
 - Payload encryption not derived from OOB secret
 - Payload integrity not protected via OOB secret
- Most impactful goal: Inject code into transmitted APK app packages

15 Checkable Requirements (R1 – R15)

Requirement	S1 (Sniff)	S2 (MITM)	S3 (Sock read)	S4 (Sock write)	S5 (FS read)	S6 (FS write)
R1: App is identifiable through Wi-Fi beacons	✓	✓	-	-	-	-
R2: Wireless protection weak	✓	-	-	-	-	-
R3: No app-level payload encryption	✓	-	✓	✓	-	-
R4: Wireless protection weak (Wi-Fi AP)	-	✓ ¹	-	-	-	-
R5: Pairing identification ambiguous (Wi-Fi Direct)	-	✓ ¹	-	-	-	-
R6: Payload encryption not derived from OOB secret	-	✓	-	-	-	-
R7: Payload integrity not protected via OOB secret	-	✓	-	-	-	-
R8: Server socket on old device accepts extra clients	-	-	✓	-	-	-
R9: No authentication for payload connections	-	-	✓	✓	-	-
R10: Wi-Fi join is device-global	-	-	-	✓	-	-
R11: Server Socket on new device accepts extra clients	-	-	-	✓	-	-
R12: No encrypted or separately transmitted checksums	-	-	-	✓	-	-
R13: User data (temporarily) stored in public file system	-	-	-	-	✓	✓
R14: No encryption for data stored in public file system	-	-	-	-	✓	✓
R15: No integrity checks for data in public file system	-	-	-	-	-	✓

¹ Either R4 or R5 is necessary for S2

Allow checking a requirement for a concrete data migration tool

Example Procedure: Determine weak or very weak wireless protection

- Identify protection scheme through Wi-Fi scanner. **If WPA2:**
 - Reverse-engineer app to locate PSK generation
 - Note down PSK length and character set
 - Calculate worst-case brute-force time on SOTA hardware
- We run each check procedure twice for each tool!
- First-party migration: Tool privileged on both devices
 - Third-party migration: Tool only privileged on new device

Evaluation Results

App	Attack Scenario					
	Proximity (M1)		Local (M2)			
	S1	S2	S3	S4	S5	S6
Google	?	-	-	-	-	-
Samsung	-	?	-	-	?	?
Vivo	?	?	?	-	-	-
Xiaomi	?	?	-	-	-	-
Oppo	? ¹	-	-	? ²	-	-
Huawei	?	?	-	-	-	-
Honor	?	?	-	-	-	-

¹ Most data types ² Only first-party migrations

5 / 7 tools

Proximity attacker can get code execution

6 / 7 tools

Proximity attacker can extract data

2 / 7 tools

Local attacker can extract data

2 / 7 tools

Local attacker can get code execution

Case Study

isec.tugraz.at ■



Samsung Smart Switch

Samsung Electronics Co., Ltd.

3.9★

512k reviews ⓘ

1B+

Downloads

- Wi-Fi Direct peer identification based on MAC and can be spoofed
- Out-of-band secret only used for authentication
- (Some) payloads AES-encrypted but key sent in plain
- Cached files in public storage
- Pictures, videos, document, call logs, messages, contacts, Wi-Fi keys...
- Code injection into transmitted APK files

Responsible Disclosure & Patches

- 16 variants of 14 end-to-end exploits reported to 7 vendors
 - 14 reports acknowledged
 - 8 CVEs, 5 high severity
- Fixes rolled out by all vendors
 - Xiaomi took almost 1.5 years to fully roll out fix
 - Vivo didn't respond to disclosure for 3 months
 - Google and Xiaomi promised CVEs but never issued them

Clone2Pwn: A Systematic Security Analysis of Data Migration Tools in the Android Ecosystem

Florian Draschbacher, Lukas Maar, Lorenz Schumm, Rene Denifl, Lukas Treffner,
Stefan Mangard

ESORICS 2026

QUESTIONS?

[Ma+2019]

Siqi Ma, Hehao Li, Wenbo Yang, Juanru Li, Surya Nepal, and Elisa Bertino. **Certified Copy? Understanding Security Risks of Wi-Fi Hotspot based Android Data Clone Services.** In: ACSAC 2020